

Pivoting ותנועה רוחבית

מודול 12 — האקינג אתי מהיסוד

◀ מעבר לרשת הפנימית שמאחורי הפריצה

◀ Port Forwarding-1 SSH Tunneling

◀ SOCKS-1 proxychains

◀ Metasploit-1 Chisel, Ligolo

למה Pivoting?

- ◀ המכונה שפרצת = כמעט אף פעם לא היעד
- ◀ שרתים רגישים ב-**רשת פנימית** לא-נגישה
- ◀ המכונה שנפרצה "רואה" רשתות שאתה לא
- ◀ מנתבים דרכה פנימה

המושגים

- ◀ **Lateral Movement** — בין מכונות באותה רשת
- ◀ **Pivoting** — מכונה כנקודת מעבר לרשת אחרת
- ◀ **Tunneling** — עטיפת תעבורה (SSH) לחציית גבול
- ◀ מזהים רשת: `ip a` , `ip route` , `arp -a`

התרחיש: Dual-Homed Host

◀ eth0 — DMZ (כאן אתה)

◀ eth1 — רשת פנימית (לא נגיש!)

◀ Pivot → Kali → מכונה פנימית

◀ Pivot-ה דרך מנתבים

3 — SSH Tunneling סוגים

- ◀ **L Local** — מביא שירות פנימי אליך
- ◀ **R Remote** — פורט על ה-Pivot אליך
- ◀ **D Dynamic** — SOCKS proxy מלא
- ◀ **-D** = הסכין השוויצרי

proxychains

◀ מריץ כל כלי דרך הפרוקסי

◀ בלקונפיג socks5 127.0.0.1 9050

◀ proxychains nmap -sT -Pn <target>

◀ חובה -sT (לא SYN) -Pn -1

Metasploit עם Pivoting

יש Meterpreter? קל ומובנה ◀

`run autoroute -s 10.10.10.0/24` ◀

מודולי MSF "רואים" את הרשת ◀

`socks_proxy` לכלים חיצוניים ◀

Ligolo-1 Chisel

◀ **Chisel** — מנהור מעל HTTP, בינארי יחיד

◀ `client R:socks + chisel server --reverse`

◀ **Ligolo-ng** — מודרני, ממשק tun, ללא proxychains

◀ מצוינים כשאין SSH / למעבדות AD

סריקה דרך ה-Pivot

`proxychains nmap -sT -Pn 10.10.10.0/24` ◀

`proxychains crackmapexec smb ...` ◀

`proxychains xfreerdp /v:...` ◀

חוזרים על מחזור: `recon → exploit → privesc` ◀

Double Pivot

- ◀ רשת שלישית שגם ה-Pivot לא רואה
- ◀ משרשרים מנהרות: $P2 \rightarrow P1 \rightarrow Kali \rightarrow$ עמוק
- ◀ נפוץ ברשתות ארגוניות רב-שכבתיות
- ◀ המפתח לחדירת AD (מודול 13)

סיכום השיטות

- SSH -L/-R/-D · Metasploit autoroute ◀
- Ligolo (tun) · Chisel (מעל HTTP) ◀
- proxychains = הדבק שמחבר הכול ◀
- Segmentation = ההגנה שעוצרת ◀

סיכום מודול 12

◀ Pivoting = גשר לרשת פנימית לא-נגישה

◀ SSH -D + proxychains = הבסיס

◀ Chisel/Metasploit/Ligolo = חלופות

◀ Double Pivot = חדירה עמוקה

◀ **תרגול** → `practice.md` · **פתרונות** → `solutions.md`